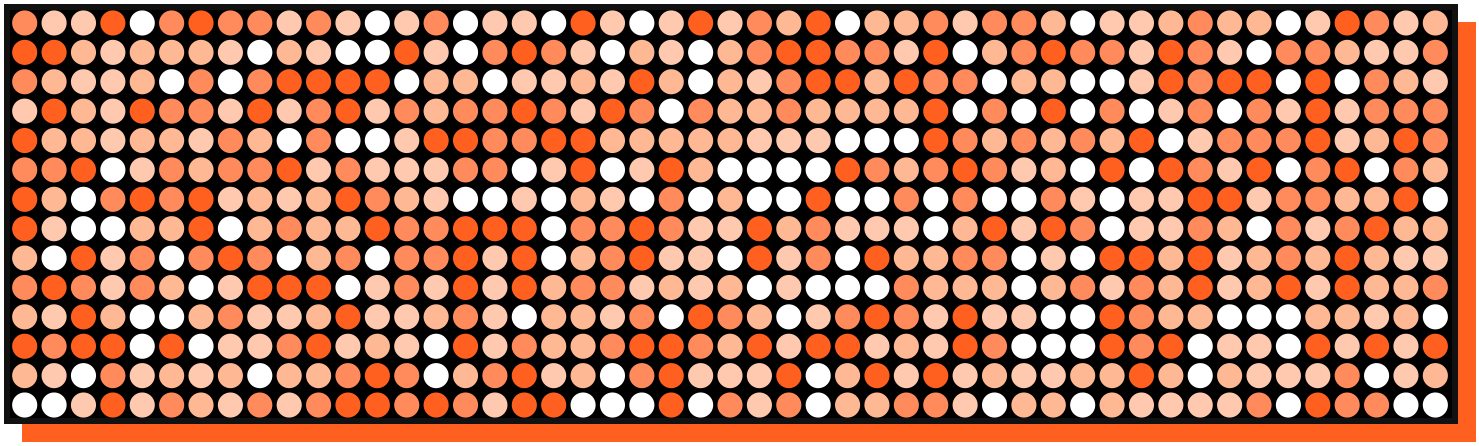
PAPYRUS EVIDENCE PACK

# SUPPLY-CHAIN EVIDENCE

Image digests, signatures, build provenance, SBOMs and vulnerability scans for this release.



| | |
|---|---|
| RELEASE<br>**0.1.0+a3d9ded** | BUILT<br>**2026-10-27T11:47:12Z** |
| IMAGE<br>**ghcr.io/beaglabs/papyrus/papyrus** | INDEX DIGEST<br>**sha256:83b1fb85aafc8c58fb481c5048f074f9e11aedbba82bbca4a1ee78bc88c91105** |

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

# CONTAINER SUPPLY-CHAIN EVIDENCE

Evidence for the published Papyrus image `ghcr.io/beaglabs/papyrus/papyrus@sha256:83b1fb85aafc8c58fb481c5048f074f9e11aedbba82bbca4a1ee78bc88c91105`, built from revision `a3d9ded116d8b3bee11c2ee6e9cd8b918566e720` on 2026-10-27T11:47:12Z. Every item below was produced or checked by tools against that digest; the commands to repeat each check are at the end.

## IMAGE

| PLATFORM | MANIFEST DIGEST | CREATED | USER | LAYERS | SBOM COMPONENTS |
|---|---|---|---|---|---|
| **linux/amd64** | `sha256:7d5e27a6ca4e60607321ee2b134e99cf8066b49db4a27ed4db48d567aa8a1dfb` | 2026-10-27T11:47:12.228066539Z | 65532:65532 | 10 | 893 |
| **linux/arm64** | `sha256:1e72ab27629544f5d8ce23acfdc7c4eac5146220792307e7053dea7309cea449` | 2026-10-27T12:12:32.83985305Z | 65532:65532 | 10 | 893 |

## SIGNATURE

The multi-arch index is signed keylessly with Sigstore cosign by GitHub Actions and recorded in the Sigstore public-good Rekor transparency log. Verification passed for workflow identity `^https://github\.com/beaglabs/papyrus/\.github/workflows/container(-multiarch)?\.yml@refs/heads/main$` from issuer `https://token.actions.githubusercontent.com`, at workflow revision `a3d9ded116d8b3bee11c2ee6e9cd8b918566e720` on `refs/heads/main`.

## BUILD PROVENANCE

A `https://slsa.dev/provenance/v1` attestation for the index digest was verified: signed by `https://github.com/beaglabs/papyrus/.github/workflows/container.yml@refs/heads/main` on a github-hosted runner from source `a3d9ded116d8b3bee11c2ee6e9cd8b918566e720`. The source repository is private, so the attestation is signed through GitHub Sigstore (private repository); the Sigstore bundle is published in this pack so it can be verified without repository access.

## VULNERABILITY SCAN

Scanned with Trivy 0.72.0 using the vulnerability database updated 2026-10-26T19:14:50.196574068Z. Counts are findings, with the number that have a fixed version available in brackets. A scan is a point-in-time result; rescan the digest for current findings.

| PLATFORM | CRITICAL | HIGH | MEDIUM | LOW |
|---|---|---|---|---|
| **linux/amd64** | 0 (0) | 0 (0) | 2 (2) | 2 (2) |
| **linux/arm64** | 0 (0) | 0 (0) | 2 (2) | 2 (2) |

## SOFTWARE BILL OF MATERIALS

Each platform has a CycloneDX and an SPDX SBOM generated from the image itself, so they include operating system packages and every transitive Node.js and Python dependency in the shipped filesystem. Timestamps and serial numbers are pinned to the image so repeated runs produce identical documents.

## HOW TO VERIFY

### SIGNATURE (COSIGN 2.4+)

```
cosign verify --certificate-identity-regexp '^https://github\.com/beaglabs/papyrus/\.github/workflows/container(-multiarch)?
\.yml@refs/heads/main$' --certificate-oidc-issuer https://token.actions.githubusercontent.com
ghcr.io/beaglabs/papyrus/papyrus@sha256:83b1fb85aafc8c58fb481c5048f074f9e11aedbba82bbca4a1ee78bc88c91105
```

### PROVENANCE (GITHUB CLI 2.60+, RUN FROM THIS PACK'S FOLDER)

```
gh attestation verify oci://ghcr.io/beaglabs/papyrus/papyrus@sha256:83b1fb85aafc8c58fb481c5048f074f9e11aedbba82bbca4a1ee78bc88c91105 --bundle
supply-chain/provenance.sigstore.json --repo beaglabs/papyrus
```

### SBOM AND SCAN (TRIVY)

```
trivy image --format cyclonedx ghcr.io/beaglabs/papyrus/papyrus@<platform digest>
```

## FILES

| FILE | SHA-256 |
|---|---|
| sbom/papyrus-linux-amd64.cdx.json | 3b90555499abf5d8be4e3888bbe174ac69034b31bfa9ddfc45ac40cf44466850 |
| sbom/papyrus-linux-amd64.spdx.json | 486f53410ffa16586362c991b1e509d290322a7eab35f286748618f58fcc7020 |
| sbom/papyrus-linux-arm64.cdx.json | cf736285d6e46e69bf471b288b72ede2f5f579ae198138c271f3f6e3b66b41ad |
| sbom/papyrus-linux-arm64.spdx.json | 93e0d9a9e2f24b0c93ad5ad571749c7eb47a7ad6a7b13605e59749a93ae51d73 |
| supply-chain/image-index.json | d530740c6008708b415640ffd8fb5c5e23e319a8630da497caa064c7e36340ec |
| supply-chain/provenance-verification.json | dabfbf4d39d07188749ba8bf1f2ca12fc8972497e04a0cb95eb700d99e6ad6b2 |
| supply-chain/provenance.sigstore.json | 7e4d7e5477d744614241bbecc78afb33d84f71bca0a86ab0ce294c2f12105151 |
| supply-chain/signature-verification.json | 1c55a75620db5dcab41d2788a3f9222853e37d930ab0f403a213198b369b0f54 |
| supply-chain/vulnerabilities-linux-amd64.json | d27a92d2962298c9b43e20cde9707f7e921e01a768f69ae8d28c392814cd9d32 |
| supply-chain/vulnerabilities-linux-arm64.json | 44ce390528d5ceb119a9b01bb5d687440b1caa4f6ee5db5f3f43c90b7f76a872 |